

Ludwig-Maximilians-Universität München

Prof. Dr. D. Kranzlmüller
Dr. Karl Furlinger
Jan Schmidt

Praktikum IT-Sicherheit
Übungsblatt 02

6. Scanner (6 Punkte)

- (a) Installieren Sie auf Ihrem pcsec-System *nmap* entweder als Paket (wenn vorhanden) oder durch Kompilieren des Quellcodes.
- (b) Scannen Sie mittels *nmap* die IP-Adressen bzw. -Bereiche 10.153.210.192/26 und ihr eigenes Subnetz:
 - i. ohne Optionen
 - ii. mit einem Fingerprint-Scan (OS Detection)
 - iii. Port 20 bis 1000
 - iv. mit einem FIN Scanerklären Sie die verschiedenen Optionen. **(1 Punkt - Theorieaufgabe)**
- (c) Wiederholen Sie den Scan ohne Optionen auf 10.153.210.192/26 von Ihrem gwsec-System. Welche zusätzlichen Informationen sehen Sie und warum könnte dies so sein? **(1 Punkt - Theorieaufgabe)**
- (d) Scannen Sie die Adresse 2001:4ca0:4001:f00::1 (*secserver*) jeweils einmal ohne Optionen, einmal auf den Ports 20-1000 und einmal mit einem FIN-Scan. Erklären Sie die Unterschiede. **(2 Punkte - Theorieaufgabe)**
- (e) Wieso ist das Brute-Force-Scannen des IPv6-Adressbereichs 2001:4CA0:4001:F00::/64 nicht praktikabel? Finden Sie einen anderen Weg, von Ihrem Router aus trotzdem alle IPv6-Rechner in diesem Segment zu finden, die auf *ICMPv6 Echo Request* reagieren. **(2 Punkte - Theorieaufgabe)**

7. Rootkit (11 Punkte)

Auf einem Ihrer Rechner *gwsec*, *pcsec1*, *pcsec2* ist ein Rootkit installiert.

- (a) Versuchen Sie, das Rootkit zu entdecken und so viele Informationen wie möglich über das Rootkit zu sammeln (dazugehörige Dateien, Prozesse, Backdoors, gesammelte Informationen). **(5 Punkte - Theorieaufgabe)**
- (b) Was würden Sie als Reaktion auf ein entdecktes Rootkit vorschlagen? **(2 Punkte - Theorieaufgabe)**
- (c) Entfernen Sie das Rootkit und alle dazugehörigen Dateien. Schließen Sie die Backdoor und machen alle Änderungen des Rootkits rückgängig. **(4 Punkte)**

8. Passwortcracker (7 Punkte)

Installieren Sie *John the Ripper*¹ entweder als Paket oder durch Kompilieren des Quellcodes.

- (a) Laden Sie mit HTTP von ihrem System aus die Datei *passwd* von <https://secp-unit.secp.lab.nm.ifi.lmu.de/static/passwd> und speichern Sie diese auf ihrem Rechner *gwsec* als */home/secpgast/Abgaben/8/passwd*. Sie enthält den Hash eines 6-stelligen Passworts. **(1 Punkt)**

Beachten Sie:

- Verändern Sie diese Datei nicht!
- (b) Welcher Algorithmus wurde für den Hash verwendet? Wie viele verschiedene Passwörter gibt es, wenn nur alphanumerische Zeichen enthalten sein dürfen? Wie lange würde es bei einer Brute-Force-Attacke mit *john* auf Ihrem System im Mittel dauern, das Passwort zu erraten? **(2 Punkte - Theorieaufgabe)**
- (c) Von zufällig generierten Passwort sind Ihnen nun folgende Eigenschaften bekannt:
 - beginnt mit zwei Kleinbuchstaben von A bis F

¹<http://www.openwall.com/john/>

- gefolgt von einem Großbuchstaben von A bis Z
- gefolgt von einer Ziffer
- gefolgt von zwei Kleinbuchstaben von A bis Z

Schreiben sie einen regulären Ausdruck, der alle möglichen Passwörter umfasst. Wie viele verschiedene Passwörter sind möglich? Wie lange würde eine Brute-Force-Attacke ungefähr dauern? **(2 Punkte - Theorieaufgabe)**

- (d) Generieren Sie mit einer Programmier- oder Skriptsprache Ihrer Wahl alle möglichen Passwörter wie in der vorherigen Aufgabe angegeben und geben Sie diese zeilenweise auf der Konsole aus. Legen Sie das Programm/Skript unter `/home/secpgast/Abgaben/8/generate_wordlist` auf Ihrem Rechner gwsec ab und achten Sie auf die Ausführbarkeit des Programms (`chmod +x`, Shebang). Verifizieren Sie die Anzahl der Einträge gegenüber dem theoretischen Wert und lassen Sie *john* im reinen *Wordlist Modus* das Passwort knacken. Speichern Sie das geknackte Passwort in `/home/secpgast/Abgaben/8/password.txt`. **(2 Punkte)**

Beachten Sie:

- Das Script muss ausführbar (`chmod +x`) in `/home/secpgast/Abgaben/8/` liegen
- Das Script muss auf dem Rechner gwsec liegen
- Achten Sie auf eine entsprechende Shebang, zum Beispiel `#!/bin/bash` für Bash
- Der *Dateiname* lautet `generate_wordlist`
- Beachten Sie, dass nur das 6 stellige Passwort in der Datei `password.txt` steht